CO2 – ASSIGNMENT 2

Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

Course Code: ITA1439 | Course Name: Ethical Hacking | Slot: A | Individual Assignment | Total Marks: 50

Student Name: Dandu Yuvasekhar Register Number: 192425271

Scope and safety statement: This report presents a documented, authorized assessment design using owned or explicitly approved domains, synthetic organizations and lab-controlled DNS configurations. The sample domains, records, counts and measurements below are illustrative test data—not claims of live testing against a real organization. No real person is targeted and no social-engineering attack is performed.

Q1 – Evaluate and Engineer a Footprinting Strategy (8 Marks)

1.1 Objective and strategy

Footprinting builds an evidence-based view of an organization's externally visible assets and public information before a penetration test. A dependable strategy uses multiple sources because WHOIS, DNS, search engines and archived pages describe different parts of the footprint and may disagree. The objective is not to collect everything indiscriminately; it is to collect only in-scope information, record its provenance, assess confidence and identify exposure that can be addressed by the owner.

Technique	Passive or active?	Purpose and limits
WHOIS/RDAP lookup	Passive	Identifies registrar, registration dates and sometimes nameservers or registrant organization. Privacy services and redaction can hide details; data may be stale.
Search-engine operators (site:, intitle:, filetype:)	Passive	Finds indexed pages and documents. Indexing is incomplete and cached results may be old; query results do not prove a file is currently hosted.
Public archive review	Passive	Shows historical pages and technology disclosures. Archived content can be outdated and must not be treated as current configuration.
DNS queries to public resolvers	Generally passive with respect to target infrastructure	Queries retrieve public DNS data; the resolver is contacted. Repeated or unusual query patterns can still be logged.
Direct DNS/service probing	Active	Sends traffic to target infrastructure and can reveal live behavior. Must be explicitly permitted, rate-limited and confined to the approved target list.
Authorized zone-transfer test	Active	AXFR is attempted only against an explicitly approved authoritative server; never assume permission from domain ownership alone.

1.2 Workflow and evidence register

• Confirm written authorization, engagement dates, exact domain and subdomain boundaries, permitted sources, query limits and third-party exclusions.

• Create a scope allowlist and a separate exclusion list; normalize domain names and record the source, collection time, query, returned value and confidence.

• Collect passive WHOIS/RDAP, search-engine results and archived material first; then retrieve public DNS records with approved tools.

• Use active checks only when specified in the Rules of Engagement (RoE); stop if a result points to an unapproved third-party system.

• Deduplicate results, validate freshness and corroborate important claims using a second independent source.

• Summarize exposed assets, uncertainty, contradictions, risk and recommended owner actions.

Suggested evidence fields: record ID, target, source/tool, exact query, timestamp (UTC), returned data, scope status, freshness, corroboration, confidence, sensitivity, analyst note and disposition. Keep raw outputs in a restricted evidence folder and publish only sanitized summaries.

1.3 Four contrasting target profiles: prediction and observation

Synthetic target	Prediction before collection	Illustrative observation	Assessment
A – Well-protected corp.example	WHOIS privacy; limited DNS; no indexed sensitive files; few subdomains.	Registrar and NS are visible; only approved web/mail records appear; search results are ordinary public pages.	Low apparent leakage. Visibility of standard records is normal, not a vulnerability.
B – Information-leaking leak.example	Public documents may expose internal naming, staff roles or software details.	A public PDF contains department names and an obsolete platform reference; search engine indexes it.	Moderate information exposure; confirm document owner and remove unnecessary metadata/details.
C – Misconfigured DNS misconfig.example	Unexpected records, stale entries or an authorized lab AXFR may expose host inventory.	Synthetic lab authoritative server permits AXFR and returns several internal-style host labels.	High information disclosure in the lab case; restrict transfers and review records.
D – Minimal footprint quiet.example	Few public pages and minimal DNS data; results may be sparse.	Only apex A/AAAA and nameserver records are observed; archives have little content.	Low visible footprint, but absence of results is not proof of absence of assets.

1.4 Reliability and contradictions

WHOIS/RDAP is authoritative for registration metadata but not for operational hosting. DNS answers depend on resolver, TTL, split-horizon policy and time. Search engines may surface deleted or cached content. Archives establish historical visibility, not current state. A contradiction—such as an archived page naming an old vendor while current DNS points elsewhere—must be recorded with dates and source context, not resolved by choosing whichever result looks more convenient. Use confidence labels: high (current authoritative source plus corroboration), medium (one credible source or partial corroboration), and low (stale, indirect or unverified).

1.5 Changed condition: 50 subdomains and third-party services

The original source mix remains suitable, but manual collection becomes inefficient and error-prone. At scale, use a scope-controlled inventory, structured outputs, deduplication, query budgets, rate limiting, ownership tagging and a review queue for third-party references. Divide collection into passive discovery, DNS verification, owner/scope validation and risk triage. Third-party services require explicit provider authorization before active testing. A fifty-subdomain inventory should be processed in batches and rechecked for freshness; broad automation must never expand the approved boundary. The strategy is therefore retained but engineered for repeatability and stronger scope enforcement.

Q2 – Build a Reliable DNS Footprinting Workflow (7 Marks)

2.1 Query workflow

For each approved hostname, query A (IPv4), MX (mail exchangers), NS (authoritative nameservers) and TXT (verification and policy text). Use dig for detailed record and TTL output and nslookup as a cross-check. Query the authoritative server when permitted to distinguish authoritative data from resolver cache. AXFR is a separate, explicitly authorized test—not a routine default.

Example commands for an approved lab domain (replace the placeholder with the authorized target):

dig approved.example A\ndig approved.example MX\ndig approved.example NS\ndig approved.example TXT\nnslookup -type=MX approved.example\ndig @ns1.approved.example approved.example AXFR

The AXFR command is executed only if the RoE explicitly permits it and the named server is an approved target. A refusal is a normal secure outcome; do not attempt transfers against unrelated domains.

2.2 Six contrasting DNS cases

Case	Prediction	Illustrative result and interpretation
1. Secure authoritative DNS	Expected records returned; AXFR refused or limited to approved secondary.	A/MX/NS/TXT are consistent; AXFR refused. Baseline secure behavior.
2. AXFR-permissive lab server	Transfer may reveal the full zone inventory.	AXFR returns synthetic hostnames and records. Significant reconnaissance uplift; restrict transfer to trusted secondaries.
3. Stale record	A record may point to retired address.	Recursive resolver returns old value until TTL expires; authoritative answer differs. Confirm TTL and authoritative data; remove obsolete record.
4. Split-horizon DNS	Internal and external clients may receive different answers.	External query returns public address; lab internal resolver returns private address. Report viewpoint and resolver used.
5. Delegated subdomain	Parent zone may show NS delegation; child data is controlled elsewhere.	Parent NS records point to provider nameservers. Treat provider as third party and require separate permission for active testing.
6. Cached/inconsistent response	Different resolvers may return different data during propagation.	One resolver shows previous MX while authoritative server shows updated MX. Record timestamps, TTL and resolver; re-query after cache expiry.

2.3 Zone-transfer risk and redesign

An unrestricted AXFR can expose a broad map of names, mail systems, development hosts and legacy services. This improves an attacker’s targeting knowledge, but does not by itself prove that those hosts are vulnerable or reachable. Risk depends on the sensitivity of disclosed names, their current validity and whether access controls exist on the services.

• Restrict AXFR to named secondary DNS servers at the network and DNS-configuration layers.

• Use TSIG to authenticate authorized transfer peers where supported; maintain and rotate keys securely.

• Monitor transfer attempts and alert on unexpected sources.

• Retest from an approved test vantage point; expected result is refusal for unauthorized clients and successful transfer only for approved secondaries.

• Re-run the workflow with authoritative and recursive queries clearly distinguished, and preserve TTL and timestamp evidence.

This redesign reduces disclosure while preserving legitimate DNS replication. TSIG is an authentication mechanism, not a replacement for access restrictions or secure key management.

Q3 – Create a Competitive-Intelligence Awareness Utility (7 Marks)

3.1 Modular workflow architecture

The utility has five modules: (1) authorized organization profile and scope; (2) public-source query planner; (3) source-specific collectors; (4) evidence normalization and risk mapping; and (5) awareness recommendations and report export. It is an awareness-analysis utility, not a tool for contacting or deceiving real people.

Public source	Example documented search operator	Possible exposed information
Job advertisements	site:jobs.example OR site:linkedin.com/jobs "Organization"	Technology stack, departments, hiring plans and role names.
Annual reports	site:example filetype:pdf "annual report"	Business structure, locations, leadership and strategic initiatives.
Press releases	site:example intitle:press OR intitle:news	New projects, vendors, events and public timelines.
Public professional profiles	site:example "security analyst" OR "IT manager"	Role names and reporting relationships; avoid collecting unnecessary personal details.
Public policy/help pages	site:example intitle:policy OR intitle:help	Processes and terminology that may be imitated in fraudulent messages.

3.2 Item-to-technique and awareness mapping

Public item (synthetic example)	Potential technique	Warning indicator	Countermeasure
Job post names a cloud platform	Phishing	Message references a real platform and asks for urgent sign-in.	Verify the URL independently; use phishing-resistant MFA.
Annual report lists a finance workflow	Pretexting	Caller claims to be a vendor and requests a payment/process exception.	Use known callback numbers and dual approval.
Press release announces a campus event	Tailgating pretext	Visitor claims event staff forgot their badge.	Require visible visitor badges and escort policy.
Public profile lists a department role	Vishing	Caller uses role-specific language to sound credible.	Do not disclose credentials or codes; call back through directory-listed contacts.
Help page describes account recovery	Phishing	Fake recovery page mimics the documented process.	Navigate from official bookmarks; report suspicious messages.

3.3 Rich, sparse and misleading test organizations

Synthetic organization	Prediction	Illustrative observation	Human-risk conclusion
RichInfo University	Many job posts, reports and profiles; higher contextual detail.	Multiple public artifacts reveal platform names and process vocabulary.	More credible pretexts are possible; improve verification habits and reduce unnecessary technical detail.
SparseCo	Few indexed pages; limited profile and report information.	Only basic contact and public service pages appear.	Lower context, but generic phishing remains possible.
MisleadWorks	Public pages contain old vendor and outdated process references.	Search results mix current and archived material.	Misinformation may cause analysts to overstate risk; verify recency before using an item.

Risk scoring is based on usefulness to a plausible deception, reliability, sensitivity and recency—not on the mere existence of public information. The most dangerous source is context-dependent; a current job advertisement can reveal technical stack, while an annual report may expose business process and authority. No single source is automatically the highest risk.

3.4 Two additive improvements

• Add public procurement/vendor notices as a source; they may reveal supplier relationships and project timing. Record only organizational facts needed for awareness analysis.

• Add a “verify independently” awareness control: employees use a known directory number or bookmarked portal rather than links or caller-provided numbers. Pair it with reporting drills using synthetic examples.

The additions fit the modular source registry and do not require redesigning the entire workflow. Their effectiveness can be evaluated by comparing source coverage and the percentage of simulated users who correctly report a suspicious scenario.

Q4 – Design a Reconnaissance Data-Validation Mechanism (6 Marks)

4.1 Validation model

Each item is checked against four dimensions: scope, freshness, duplication and source reliability. Scope is checked first because out-of-scope data must not proceed into analysis. Freshness is assessed using collection time, TTL or publication date. Duplicates are merged while retaining provenance. Reliability is rated based on authority, corroboration and whether the result is direct or inferred.

Status	Decision rule	Action
PASS	In-scope, sufficiently current, unique after normalization and supported by a credible source.	Allow into validated dataset.
RE-CHECK	In scope but stale, conflicting, incomplete or from a source needing confirmation.	Re-query or corroborate; retain as provisional meanwhile.
FAIL / REJECT	Out of scope, unverifiable, prohibited personal data or clearly irrelevant.	Quarantine or reject; do not use for target analysis.

4.2 Test sequences and predicted outcomes

Sequence	Inputs	Predicted result	Reason
A – All valid	5 in-scope, current, unique, reliable items	5 pass; 0 fail; 0 re-check	All validation conditions satisfied.
B – Scope violation	4 valid + 2 unrelated-domain records	4 pass; 2 fail	Scope gate rejects unrelated assets immediately.
C – Stale items	3 current + 2 old DNS/document records	3 pass; 0 fail; 2 re-check	Re-query or confirm whether historical facts remain relevant.
D – Duplicates	4 unique items + 3 normalized duplicates	4 pass; 0 fail; 3 merged	Preserve original source references in the merged record.
E – Mixed adversarial	3 valid + 1 out-of-scope + 1 stale + 1 unverifiable	3 pass; 2 fail; 1 re-check	Reject scope/unverifiable records; confirm stale one.

4.3 Order, effort and scale

Recommended order: (1) normalize and check scope; (2) reject prohibited or unverifiable entries; (3) deduplicate; (4) assess freshness; (5) assess source reliability and corroborate; (6) assign confidence and disposition. Scope-first prevents wasted work and avoids processing out-of-scope data. Deduplication before expensive corroboration reduces repeated checks. Reliability and freshness may be iterated when a contradiction is discovered.

For one target, manual validation may be manageable. At fifty targets, use a schema, canonical hostname normalization, deduplication keys, TTL-aware refresh rules and a review queue. If 500 raw entries contain 20% duplicates, roughly 400 unique candidates remain before other checks; the exact pass/re-check/fail count depends on scope and quality, so the pipeline should report observed counts rather than assume every item is valid. Automation accelerates routine checks but human review remains necessary for ambiguous ownership and conflicting evidence.

Q5 – Evaluate Footprinting of a Hierarchical Organization (7 Marks)

5.1 Representation and traversal

Represent the public footprint as a rooted tree. The root is the authorized parent domain; children are approved subdomains; lower levels may represent department services, application endpoints or approved third-party dependencies. Each node contains an identifier, parent, type, scope status, source, observed data and terminal flag.

Boundary condition: visit a node only if it is explicitly within the engagement allowlist or covered by an approved wildcard rule. Stop expanding when a node is out of scope, terminal, has no discovered children, or reaches the agreed depth/query budget. A node with no public data is recorded as an empty terminal node—not silently omitted.

5.2 Example structures and predicted coverage

Structure	Synthetic hierarchy	Predicted nodes	Expected behavior
Shallow	root → www, mail, portal	4 total	Visit root and three children; all branches terminate.
Deep	root → app → api → auth → test-lab	5 total	Follow the single chain to the approved depth; test-lab is terminal.
Irregular	root → web (2 children), mail (1), dept (3); one empty branch	8 total	Visit all authorized nodes; empty branch is logged as no public data.
Boundary case	root → vendor.example (third party, not approved)	2 discovered, 1 visited beyond root?	Record reference, mark excluded and do not traverse or probe vendor node.

5.3 Pseudocode

queue ← [approved root]\nvisited ← empty set\nwhile queue is not empty:\n node ← remove_front(queue)\n if node in visited: continue\n if not scope_allowlist.contains(node): record excluded; continue\n visited.add(node); collect permitted passive evidence(node)\n if node.terminal or depth(node) ≥ approved_limit: continue\n children ← discover_children_from_approved_sources(node)\n if children is empty: record node as empty terminal\n else: add only in-scope children to queue

Breadth-first traversal gives a level-by-level inventory and makes boundary review visible. Depth-first traversal may be suitable for a narrow branch but can delay discovery of sibling branches. Both are correct if they share the same scope and terminal conditions.

5.4 Depth, branching and ad-hoc comparison

Depth increases the number of sequential decisions and the chance of stale or third-party references. Branching increases the number of candidate nodes and therefore the review workload. A broad tree with branching factor b and depth d can grow rapidly; a complete tree has approximately (b^(d+1)−1)/(b−1) nodes when b is not 1. Real footprints are irregular, so measured counts should be reported. Systematic traversal offers repeatable coverage and explicit stopping rules; ad-hoc browsing may be faster for a tiny target but tends to miss branches, duplicate observations and blur scope boundaries.

Q6 – Evaluate Footprinting Approaches Under Constraints (7 Marks)

6.1 Approaches and outputs

Approach	Workflow	Output	Trade-off
Passive OSINT-first	WHOIS/RDAP, search operators, public archives, public DNS via resolver; no direct service probing.	Public-source inventory, citations, historical and DNS observations.	Quiet and low-impact, but incomplete and dependent on indexing.
Active authorized DNS/service checks	Query approved authoritative DNS; validate approved hosts/services with conservative limits.	Current responses, TTLs, service reachability and configuration evidence.	More current and specific, but creates target traffic and detection/availability risk.

6.2 Illustrative scale measurements

The following table is a controlled planning estimate to compare workflow complexity; it is not a measured live experiment. Actual query counts and durations must be recorded during the authorized lab run.

Scope size	Passive steps (estimate)	Active checks (estimate)	Engineering interpretation
1 domain	6–10 source/query steps	4–8 DNS checks	Either approach is feasible; passive-first reduces impact.
5 subdomains	15–30 collection steps	20–40 targeted queries	Batching and deduplication become useful.
20 subdomains	40–100 source steps	80–160 checks	Manual active checking becomes time-consuming; automate within allowlist.
50 subdomains + providers	100–250 source steps	200–500 potential checks	Unbounded active probing becomes impractical and may cross provider scope; staged, allowlisted checks are necessary.

6.3 Redundancy and recommendation

Passive collection repeats effort when the same indexed document appears under several search queries or archived versions. Active collection repeats effort when multiple tools query identical records or when TTL-aware results are not cached. Normalize targets, deduplicate queries, cache results only for their valid lifetime, and keep source provenance so repeated evidence is not mistaken for independent corroboration.

The faster approach is not always better: speed can increase noise and scope risk, while quiet collection may omit important current exposures. For a small teaching engagement, use passive-first collection followed by a few owner-approved active validations. For a large real assessment, combine passive discovery with automated, rate-limited active checks on an explicit allowlist, apply risk tiers and stop conditions, and require separate permission for third-party systems. In teaching, synthetic domains and lab DNS cases provide repeatability without contacting real individuals or launching attacks.

Q7 – Integrated Review: Diagnose, Redesign and Defend (8 Marks)

7A. Diagnose the limitation (2 marks)

Selected workflow: Q4 reconnaissance data validation. The original naïve order checks freshness and source credibility before verifying scope and deduplicating. This creates a bottleneck: analysts spend time researching stale or duplicated records that should never be used, and out-of-scope items may enter intermediate analysis. The root causes are poor ordering and redundant corroboration.

7B. Evaluation criteria (1 mark)

Criterion	Definition
Scope compliance	Percentage of processed records that are in the approved inventory; target 100%.
Coverage	Percentage of unique, in-scope expected test records correctly retained or routed for re-check.
Query count	Number of external confirmation queries made after initial collection.
Source reliability	Share of retained records supported by authoritative or corroborated evidence.
Effort	Number of validation operations or analyst review steps.

7C. Redesign (2 marks)

Redesigned order: normalize → scope gate → reject prohibited/unverifiable → deduplicate → freshness check → reliability/corroboration → confidence label → report. The scope gate is deterministic and cheap; duplicate merging prevents repeated expensive checks. A trade-off is that early rejection may require careful handling of uncertain aliases: ambiguous ownership should be held for scope review rather than automatically rejected as definitely unrelated.

7D. Quantitative comparison under equivalent conditions (2 marks)

Illustrative synthetic benchmark: 100 raw records consisting of 60 valid unique items, 15 duplicates, 10 out-of-scope items, 10 stale items and 5 unverifiable items. Expected final disposition is 60 pass, 15 duplicate-merged, 10 fail for scope, 10 re-check for freshness and 5 fail for unverifiability. The original order performs 100 initial credibility/freshness operations and then discovers scope violations and duplicates. The redesigned order performs 100 inexpensive normalization/scope checks, merges duplicates before expensive validation, and runs freshness/reliability checks on 60 unique in-scope candidates plus the 10 stale candidates requiring confirmation. Under an illustrative one-check-per-candidate model, expensive checks fall from 100 to 70 (30% reduction), while scope compliance remains 100% and all 60 valid items are retained. This is a modeled comparison, not an empirical network measurement.

Metric	Original order (illustrative)	Redesigned order (illustrative)
Scope compliance	100% only after late filtering; risk of intermediate misuse	100% before detailed analysis
Unique valid items retained	60	60
Duplicate handling	15 repeated checks possible	15 merged before expensive checks
Expensive validation checks	100	70
Out-of-scope items used in analysis	Potentially during intermediate stages	0

7E. Final engineering judgment (1 mark)

The redesign meets its objective in the modeled test: it preserves valid coverage, ensures scope is checked first and reduces expensive validation work by an estimated 30%. The original workflow may still be preferable for a very small dataset where ordering has negligible cost or where source reliability must be assessed immediately to triage an urgent report. For repeatable assessments and larger inventories, the redesigned order is stronger because it makes scope compliance an early invariant and minimizes redundant work. A real pilot should record actual query and review counts to validate the estimate.

Overall Conclusion

This assignment develops a complete, evidence-oriented footprinting and awareness workflow for authorized assessments. It combines passive OSINT with carefully bounded DNS validation, distinguishes current observations from historical or cached data, validates scope and source quality, models organizational footprints hierarchically, and evaluates scale using explicit criteria. Its central engineering judgment is that collection quality depends not on volume alone but on authorization, provenance, freshness, corroboration and disciplined stopping conditions. The redesigned workflows provide repeatable coverage while reducing unnecessary queries and protecting real people and third-party systems.